

Vulnerability Analysis Tools

The tools

Tool	What it finds
OpenVAS (Greenbone)	Network vuln scanner with a rich CVE database
Nessus	Commercial scanner (free for 16 IPs – good for learning)
Nikto	Webserver misconfigs and known-issue scanner
sqlmap	Automated SQL injection detection + exploitation
gobuster / ffuf / feroxbuster	Directory & file brute-forcing, vhost fuzzing
WPScan	WordPress plugins/themes/users CVEs
nmap NSE	600+ scripts (vuln, brute, discovery)

Workflow

1. OpenVAS scan -> CVE list per host
2. nmap --script vuln on interesting services
3. nikto on web targets
4. gobuster to discover hidden paths
5. sqlmap on any parameter you suspect
6. Rank: exploitability x asset value

Directory brute-force you should always try

```
gobuster dir -u http://10.0.0.20 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,html
ffuf -w /usr/share/wordlists/subdomains-top1million-20000.txt -u http://10.0.0.20/FUZZ
```

sqlmap essentials

```
sqlmap -u 'http://10.0.0.20/search.php?q=test' --batch --dbs  
sqlmap -u 'http://10.0.0.20/login.php' --forms --batch --dbs
```

It enumerates and (if you allow) dumps data – in a lab only!

Reading the findings

A scanner's "critical" from a default network scan is a lead, not a verdict

Reproduce: connect to the service yourself before writing a finding

False positive discipline matters; triage = verify + rank

The professional habit: scanners *suggest*, you *prove*. Every candidate finding gets a manual confirmation before it earns report space.

[← Information Gathering Tools](#)

[Exploitation & Password Cracki...](#)